

SECURITY BREACH IMPACT REPORT

Ransomware Incident — Orion Health Services

Classification:	CONFIDENTIAL – EXECUTIVE USE ONLY
Incident Date:	Monday, May 4th, 2026
Report Date:	7 May 2026
Prepared By:	Neel Soneji - Cybersecurity Analyst Graduate, Internal Security Team
Distribution:	Executive Leadership Team, Board of Directors
Incident Type:	Ransomware Attack

This document contains sensitive incident response information and is intended solely for authorised recipients.

1. Executive Summary

On Monday morning, Orion Health Services experienced a targeted ransomware attack that resulted in the encryption of critical internal systems and the potential compromise of sensitive employee and patient data. The attack originated from a phishing email sent to a member of the finance team, which contained a malicious Excel attachment that initiated the infection chain.

By midday, multiple employees had been locked out of key systems, and a ransom note was discovered on the shared drive under the .orionlock file extension. The incident affected the organization's file server, HR and finance systems, and partially encrypted the backup server — significantly limiting immediate recovery options.

This report provides a comprehensive analysis of the incident, its technical characteristics, business impact, and recommended remediation actions.

Overall Severity	Systems Affected	Data Compromised
CRITICAL	3 Primary + Backup	PII, PHI, Credentials

2. Incident Timeline

The following table summarizes the known sequence of events from initial compromise to detection and response activation.

Time	Phase	Event
Prior to Monday	Initial Access	Phishing email with malicious Excel attachment sent to finance team member. Attachment executed upon opening, initiating payload delivery.
Monday — Early AM	Execution & Lateral Movement	Attacker used Mimikatz to harvest credentials from memory. Lateral movement across internal network using stolen credentials. Suspicious login observed from overseas IP address.
Monday — Mid AM	Persistence & Exfiltration	Unusual outbound network traffic detected by IT team. Attackers accessed file server, HR/finance systems, and backup server. Data likely exfiltrated at this stage.
Monday — Midday	Ransomware Deployment	Ransomware payload deployed. Files encrypted with .orionlock extension across affected systems. Ransom note discovered on shared drive. Multiple employees locked out of systems.
Monday — Post Midday	Detection & Response	Incident formally escalated. Security team engaged. Containment procedures initiated. Incident response team assembled.

3. Attack Vector & Technical Analysis

3.1 Initial Entry Point

The attack originated through a spear-phishing email targeting a member of the finance team. The email contained a malicious Microsoft Excel attachment that, when opened, executed an embedded macro or exploit to deliver the ransomware payload. This technique is consistent with modern ransomware operators who conduct reconnaissance to identify high-value targets with system access.

3.2 Attack Methodology

The attack followed a well-structured multi-stage pattern consistent with a sophisticated threat actor:

#	Stage	Description
1	Initial Access	Phishing email with malicious Excel attachment (T1566.001 — Spear phishing Attachment)
2	Execution	Malicious macro or exploit triggered on opening the Excel file to run a dropper payload
3	Credential Harvesting	Mimikatz deployed to extract plaintext credentials and NTLM hashes from LSASS memory (T1003.001)
4	Lateral Movement	Stolen credentials used to access additional systems including file server, HR, and finance systems
5	Discovery	Attacker enumerated network shares, backup locations, and high-value data stores
6	Exfiltration	Sensitive data likely exfiltrated prior to encryption (double-extortion model suspected)
7	Impact	Ransomware deployed, files encrypted with .orionlock extension, systems rendered inoperable

3.3 Indicators of Compromise (IOCs)

The following indicators were identified during the investigation and should be used for threat hunting and ongoing monitoring:

IOC Type	Indicator	Significance
Network	Overseas IP Login	Unauthorized access from foreign IP — suggests credential theft and remote attacker control
Tooling	Mimikatz Usage	Open-source credential harvester used to extract passwords from Windows LSASS memory — enables full domain compromise
File System	.orionlock Extension	Custom file extension appended to encrypted files — used to identify ransom victims and as a brand by the ransomware group
Behavior	Unusual Outbound Traffic	High-volume outbound network traffic prior to encryption — likely indicative of data exfiltration

Artefact	Ransom Note on Shared Drive	Ransom note deposited on shared drive, confirming ransomware operator access and intent
----------	-----------------------------	---

4. Impact Assessment

4.1 Systems Affected

The following systems were compromised or disrupted as a result of the attack:

System	Status	Impact
File Server	ENCRYPTED	All files encrypted. Access to shared documents, records, and operational data lost.
HR & Finance Systems	ENCRYPTED	Payroll, employee records, and financial data encrypted. Business operations severely disrupted.
Backup Server	PARTIAL	Partially encrypted. Full recovery from backup is not guaranteed. Recovery timeline extended significantly.

4.2 Data Compromised

Data Category	Classification	Privacy / Regulatory Implications
Employee Payroll Records	HIGH	Contains salary, TFN, and bank account details. Notifiable Data Breach under Australian Privacy Act 1988.
Patient Appointment Schedules	CRITICAL	Protected Health Information (PHI). Regulated under the My Health Records Act and Privacy Act. Potential breach of clinic contractual obligations.
Internal System Credentials	HIGH	Risk of further system compromise. Immediate credential rotation required. Potential for persistent attacker access.

4.3 Business Impact

- Operational disruption to clinical software services provided to clinic customers across Australia and New Zealand
- Potential contractual breaches with clinic partners due to service downtime and data exposure
- Reputational risk associated with handling of sensitive patient health information
- Regulatory exposure under the Privacy Act 1988 (Cth), Notifiable Data Breaches (NDB) scheme, and applicable state health legislation
- Financial impact from potential ransom demand, remediation costs, legal fees, and regulatory penalties
- Employee productivity loss and operational downtime across finance, HR, and file management functions

5. Regulatory & Legal Obligations

Given the nature of data compromised, Orion Health Services may have reporting obligations under the following frameworks:

Obligation	Timeframe	Action Required
Notifiable Data Breach (NDB) — OAIC	30 days	Assess whether breach is likely to result in serious harm. Notify OAIC and affected individuals if threshold is met.
Australian Privacy Act 1988 (Cth)	Immediate	Review obligations under the Australian Privacy Principles. Engage legal counsel for guidance on breach notification.
My Health Records Act 2012	Immediate	If patient health records are implicated, mandatory notification to the Australian Digital Health Agency may be required.
New Zealand Privacy Act 2020	72 hours	Assess whether the Privacy Commissioner of NZ must be notified given the presence of NZ clinic customers.
Contractual Obligations (Clinic Partners)	ASAP	Review SLAs and data processing agreements with clinic partners. Provide incident notification as contractually required.

Note: Legal counsel should be engaged immediately to advise on the full scope of notification obligations. The above timeframes are indicative and may vary based on the outcome of a formal breach assessment.

6. Containment & Remediation Actions

6.1 Immediate Actions (0–24 Hours)

- **Priority:** Isolate all affected systems from the network to prevent further spread
- **Priority:** Preserve forensic evidence — do not power off affected servers; image drives where possible
- **Priority:** Revoke and rotate all compromised credentials, system accounts, and privileged access tokens
- **Priority:** Block suspicious overseas IP addresses at the perimeter firewall and WAF
- **Priority:** Notify executive leadership, legal counsel, and engage external incident response support if required
- **Priority:** Assess the integrity of backup data and identify the most recent clean restore points

6.2 Short-Term Actions (24–72 Hours)

- Conduct full memory forensics and endpoint analysis across all devices
- Perform threat hunting across the environment for additional Mimikatz or credential harvesting artefacts
- Initiate formal breach assessment to determine NDB notification obligations
- Restore systems from verified clean backups; prioritise patient-facing and clinical services
- Implement emergency MFA enforcement across all remaining active accounts
- Engage legal counsel to assess contractual and regulatory notification requirements

6.3 Medium-Term Actions (1–4 Weeks)

- Deploy endpoint detection and response (EDR) tooling across all endpoints
- Conduct a full Active Directory audit; reset all domain accounts and review privileged access
- Implement email security controls — DMARC, DKIM, SPF, and attachment sandboxing
- Review and harden macro execution policies across all Microsoft Office environments
- Engage a third-party forensics firm to conduct root cause analysis and full compromise assessment
- Deliver mandatory security awareness training with a focus on phishing recognition

6.4 Long-Term Improvements (1–3 Months)

- Implement a zero-trust network architecture to limit lateral movement potential
- Establish offsite and air-gapped backup infrastructure with regular integrity testing
- Develop and test an updated Incident Response Plan (IRP) and Business Continuity Plan (BCP)
- Conduct a tabletop exercise simulating ransomware scenario for the executive and IT teams
- Implement privileged access management (PAM) for all administrative credentials
- Establish continuous security monitoring and a formal Security Operations Centre (SOC) function

7. Residual Risk Register

The following risks remain elevated following the initial incident and require ongoing management and monitoring:

Risk	Likelihood	Severity	Recommended Control
Persistent attacker presence in environment	HIGH	CRITICAL	Full forensic investigation; complete environment rebuild if persistence confirmed
Secondary ransomware deployment via retained access	MEDIUM	CRITICAL	Network segmentation; EDR deployment; active threat hunting
Data published / sold by threat actor	HIGH	HIGH	Dark web monitoring; engage legal for data breach notification and mitigation options
Regulatory penalties and legal action	MEDIUM	HIGH	Proactive OAIC and NZPC engagement; appoint privacy counsel
Incomplete backup recovery resulting in data loss	HIGH	HIGH	Assess backup integrity; implement 3-2-1 backup strategy with offsite copies
Reputational damage and client loss	MEDIUM	MEDIUM	Transparent communication strategy; proactive partner notification; public relations support

8. Recommendations Summary

The following high-priority recommendations are presented to the Executive Team for action and endorsement:

#	Recommendation	Priority	Owner
1	Engage external incident response and digital forensics firm immediately	CRITICAL	CISO / CEO
2	Initiate formal NDB breach assessment and notify OAIC if threshold is met	CRITICAL	Legal / Privacy Officer
3	Enforce organization-wide MFA and credential rotation within 24 hours	CRITICAL	IT Security Team
4	Notify clinic partners and customers of potential data exposure	HIGH	Executive / Legal
5	Deploy EDR solution across all endpoints and servers	HIGH	IT Security Team
6	Rebuild backup infrastructure with air-gapped and offsite replication	HIGH	IT Infrastructure
7	Implement email security gateway with attachment sandboxing	HIGH	IT Security Team
8	Deliver mandatory phishing awareness training across all staff	MEDIUM	HR / IT Security
9	Develop and test updated Incident Response Plan and BCP	MEDIUM	CISO / Business Operations
10	Commission annual penetration testing and red team exercises	MEDIUM	CISO

9. Report Sign-Off & Authorisation

This report has been prepared by the Internal Security Team in response to the ransomware incident identified on Monday. The findings and recommendations are based on information available at the time of preparation and are subject to update as the investigation progresses.

This report is classified as CONFIDENTIAL. It should not be distributed beyond authorized recipients without the express approval of the Chief Information Security Officer or Chief Executive Officer.

Role	Name	Signature / Date
Prepared by	Cybersecurity Analyst Graduate	
Reviewed by	IT Security Manager	
Approved by	Chief Information Security Officer	
Endorsed by	Chief Executive Officer	